A Deterministic, CVSS–Environmental Method for FedRAMP Rev5 VDR/VER Vulnerability Prioritization

stackArmor

Draft Whitepaper / Request for Comments

June 2026 | Status: Informational Draft

Abstract

FedRAMP Rev5 introduces a Vulnerability Disclosure Report (VDR) and Vulnerability Evaluation Requirements (VER) that define *Potential Agency Impact* (PAIN, levels N1–N5) and a remediation–timeframe matrix, together with evaluation rules for likely exploitability and internet reachability. FedRAMP deliberately does *not* prescribe how to derive a PAIN level from an individual vulnerability on a specific asset. This memo argues that the missing classifier already exists, in standardized form, as the **Environmental metric group of CVSS**: the Confidentiality, Integrity and Availability *Requirements* (CR/IR/AR) and the Modified Impact Sub-Score were designed precisely to re-weight a vulnerability's impact by what is at stake in a given deployment. We present a closed-form, reproducible mapping from FedRAMP's requirements onto CVSS Environmental metrics, derive PAIN and the remediation deadline from it, and give fully worked calculations. We also present an *example* mechanism — "asset archetypes" — for assigning CR/IR/AR systematically, while emphasizing that each Cloud Service Provider (CSP) SHOULD derive its own assignment from its system categorization. A reference architecture and a sample scan complete the memo.

Contents

1 Status of This Memo and Terminology

This document is an informational draft circulated for comment. It does not define a FedRAMP requirement; it proposes a standardized *method* for satisfying existing VDR/VER requirements.

The key words MUST, MUST NOT, SHOULD, SHOULD NOT, and MAY are to be interpreted as described in RFC 2119.

PAIN
Potential Agency Impact, the FedRAMP N1–N5 rating of a finding.

CR/IR/AR
The CVSS Environmental Confidentiality / Integrity / Availability *Requirements* of an asset.

ISC
Impact Sub-Score (here, the CVSS *Modified* Impact Sub-Score).

LEV / NLEV
Likely Exploitable / Not Likely Exploitable (a VER axis).

IRV / NIRV
Internet Reachable / Not Internet Reachable (a VER axis).

Class
The provider Certification Class (A–D) selecting a remediation table.

2 Motivation: the gap between VDR/VER and the scanner

A vulnerability scanner emits, per finding, a CVE identifier, a qualitative severity, and (often) a CVSS Base vector. FedRAMP Rev5 VDR/VER, by contrast, asks the provider to answer a different question: *what is the potential impact on the agency if this vulnerability is exploited on this asset, and how quickly must it therefore be remediated?* The two are not the same. A "Low"-rated CVE on a crown-jewel datastore can carry more agency impact than a "High"-rated CVE on a throwaway sandbox.

FedRAMP supplies the *output* vocabulary (the PAIN buckets and the remediation matrix) and the *evaluation axes* (likely-exploitable, internet-reachable) but leaves the *classifier* — the function from (CVE, asset) to PAIN — to the provider. An ad-hoc or analyst-by-analyst classifier is neither reproducible nor defensible. This memo supplies a deterministic one.

3 Key insight: FedRAMP's requirements are CVSS Environmental metrics

The central claim of this memo is that FedRAMP's notion of "impact on the agency" maps, almost one-to-one, onto metrics that already exist in the CVSS v3.1 specification's *Environmental* group. The Environmental group exists for exactly this purpose: to let the consuming organization re-score a vulnerability according to the criticality of the affected asset in *its* environment.

FedRAMP VDR/VER concept	**CVSS mechanism that satisfies it**
Asset data sensitivity / FIPS-199 C-I-A categorization	Security Requirements `CR`, `IR`, `AR`
Magnitude of potential agency impact	Modified Impact Sub-Score (`ISC`)
Likely exploitable (VER)	`LEV`: exploit maturity / EPSS threshold
Internet reachable (VER)	`IRV`: deployment/network context
Single- vs. multi-agency blast radius	scope multiplier on the PAIN tier
Provider Certification Class	selector of the remediation deadline table

Table 1: FedRAMP requirements fall directly onto CVSS Environmental metrics.

The consequence is that a conforming implementation need not invent a bespoke risk algebra. It need only (a) assign each asset its CR/IR/AR, and (b) evaluate the two VER axes. The arithmetic that turns those inputs into a defensible impact magnitude is the published CVSS Environmental formula.

4 The model

We define PAIN as a function of a *severity* term and a *scope* term:

$$\text{PAIN(finding)} \;=\; f\big(\text{SEVERITY},\ \text{SCOPE}\big).$$

SEVERITY answers "how badly does this vulnerability's impact land on *this* asset?" — the CVE's impact metrics re-weighted by the asset's CR/IR/AR. **SCOPE** answers "how many agencies' data does the asset hold?" — single (1) or multiple (>1). SEVERITY is mapped to a FedRAMP customer-effect word (Minimal, Narrow, Disruptive, Debilitating); the word and scope together select the N-level.

5 The mathematics

All constants below are taken *verbatim* from the CVSS v3.1 specification; only the normalization and the word thresholds (Section 5) are additions.

Impact metric weights. Each of the affected vulnerability's Confidentiality, Integrity and Availability impact metrics (C, I, A), read from the CVSS Base vector, takes a weight:

$$C, I, A \in \{\,\text{None} = 0, \quad \text{Low} = 0.22, \quad \text{High} = 0.56\,\}.$$

Security Requirement weights. Each asset's Requirement (CR, IR, AR) takes a multiplier:

$$\mathrm{CR}, \mathrm{IR}, \mathrm{AR} \in \{\, \mathrm{Low} = 0.5, \quad \mathrm{Medium} = 1.0, \quad \mathrm{High} = 1.5 \,\}.$$

Modified Impact Sub-Score. The per-dimension impacts and requirements combine as a probabilistic union — the share of the asset left uncompromised on each dimension is multiplied, and the complement is the overall impact:

$$\mathrm{ISC} \;=\; \min\Big[\, 1 - \big(1 - C{\cdot}\mathrm{CR}\big)\big(1 - I{\cdot}\mathrm{IR}\big)\big(1 - A{\cdot}\mathrm{AR}\big), \;\; 0.915 \,\Big]. \tag{1}$$

The cap $0.915 = 1-(1-0.56)^3$ is the CVSS ceiling (all-High impact at Medium requirements). We then normalize to a unit scalar:

$$S \;=\; \frac{\mathrm{ISC}}{0.915} \;\in\; [0,1]. \tag{2}$$

Severity word. S is bucketed into a FedRAMP customer-effect word by three cut points $(\theta_1, \theta_2, \theta_3)$:

$$W(S) \;=\; \begin{cases} \text{Minimal} & S < \theta_1 \\ \text{Narrow} & \theta_1 \le S < \theta_2 \\ \text{Disruptive} & \theta_2 \le S < \theta_3 \\ \text{Debilitating} & S \ge \theta_3 \end{cases} \qquad (\theta_1, \theta_2, \theta_3) = (0.25,\; 0.55,\; 0.85). \tag{3}$$

The cut points are the model's *one* calibratable judgment. They SHOULD be documented and back-tested against analyst-rated findings, and an implementation MUST treat them as governed configuration rather than an in-band, ad-hoc setting.

Scope and the N-level. Let $m \in \{0,1\}$ be the asset's multi-agency flag. Some asset classes are *scope amplifiers* (shared infrastructure whose compromise crosses tenant boundaries); for those, an offering that itself serves more than one agency ($\textsc{cso}_{>1}$) is treated as multi-agency regardless of the per-asset flag:

$$m^* \;=\; m \;\vee\; \big(\text{amplifier} \;\wedge\; \textsc{cso}_{>1}\big). \tag{4}$$

The N-level follows from the word and effective scope:

$$\mathrm{PAIN} = \begin{cases} \text{N1} & W = \text{Minimal} \\ \text{N2} & W = \text{Narrow} \\ \text{N3} & W = \text{Disruptive},\; m^* = 0 \\ \text{N4} & W = \text{Disruptive},\; m^* = 1 \;\text{ or }\; W = \text{Debilitating},\; m^* = 0 \\ \text{N5} & W = \text{Debilitating},\; m^* = 1 \end{cases} \tag{5}$$

Technical-impact floor (optional refinement). Where an authoritative source (e.g. CISA Vulnrichment SSVC) provides a *technical impact* of `total`, the impacts that the CVE *does* touch may be floored to High before Eq. (1):

$$\hat{X} = \begin{cases} 0.56 & X > 0 \text{ and tech. impact} = \texttt{total} \\ X & \text{otherwise} \end{cases} \qquad X \in \{C, I, A\}.$$

Crucially the floor MUST NOT invent impact on a dimension the CVE marks None ($X = 0$ stays 0); `partial` or absent leaves the vector unchanged.

6 Fail-safe behavior

Missing metadata MUST NOT *lower* PAIN. An asset that carries no classification SHOULD resolve to a deliberately conservative default (e.g. CR/IR/AR all High), which scores loudly and surfaces the asset for classification rather than hiding it. "Unknown" is treated as "serious until proven otherwise."

7 Remediation: the VDR-TFR-PVR matrix

The remediation deadline is selected by three values: the provider Certification Class, the PAIN level, and an exploitability *column* derived from the two VER axes:

$$\text{deadline} = M\big[\,\text{Class}\,\big]\big[\,\text{PAIN}\,\big]\big[\,\text{column}\,\big], \qquad \text{column} \in \{\,\text{LEV+IRV},\ \text{LEV+NIRV},\ \text{NLEV}\,\}.$$

where, for a provider-selected EPSS threshold θ_{epss} (this memo uses 0.70):

$$\text{LEV} \ = \ \big(\text{EPSS} \geq \theta_{\text{epss}}\big) \ \vee \ \big(\text{exploitation} = \text{active}\big), \qquad \text{IRV} = \text{asset is internet-reachable.}$$

The day-valued tables are given in Appendix B. PAIN-1 carries no FedRAMP deadline.

8 Worked examples

We use C, I, A for impacts and CR/IR/AR for requirements; all arithmetic follows Eqs. (1)–(5).

Example 1 — RCE on a crown-jewel datastore, multi-agency. $C = I = A = 0.56$ (High), CR=IR=AR=1.5 (High), $m = 1$.

$$\begin{aligned} \text{ISC} &= \min\big[\,1 - (1 - 0.84)^3,\ 0.915\,\big] = \min[\,0.9959,\ 0.915\,] = 0.915, \\ S &= 0.915/0.915 = 1.000 \ \Rightarrow\ W = \text{Debilitating}, \\ m^* &= 1 \ \Rightarrow\ \boxed{\text{N5}}. \end{aligned}$$

Example 2 — the same CVE on a sandbox, single-agency. $C = I = A = 0.56$, CR=IR=AR=0.5 (Low), $m = 0$.

$$\begin{aligned} \text{ISC} &= 1 - (1 - 0.28)^3 = 1 - 0.72^3 = 0.6268, \\ S &= 0.6268/0.915 = 0.685 \ \Rightarrow\ \text{Disruptive} \ \Rightarrow\ \boxed{\text{N3}}. \end{aligned}$$

Identical vulnerability, opposite ends of the matrix — the asset half of the score (CR/IR/AR) is doing the work.

Example 3 — availability-only DoS on a message backbone. A CVE with $C = 0,\ I = 0,\ A = 0.56$ (e.g. a parser DoS), on an asset with CR=IR=AR=1.5, $m = 0$. EPSS = 0.76, not internet-reachable.

$$\begin{aligned} \text{ISC} &= 1 - (1 - 0)(1 - 0)(1 - 0.84) = 1 - 0.16 = 0.84, \\ S &= 0.84/0.915 = 0.918 \ \Rightarrow\ W = \text{Debilitating},\ m^* = 0 \ \Rightarrow\ \boxed{\text{N4}}. \end{aligned}$$

The single dimension $A \cdot \text{AR} = 0.84$ alone clears the Debilitating bar. Remediation: LEV (EPSS ≥ 0.70) $\wedge$ NIRV; at Class C this is $M[\text{C}][\text{N4}][\text{LEV+NIRV}] = 8$ days. Note this finding may carry a *Low* vendor severity — PAIN is decoupled from the qualitative label.

Example 4 — information disclosure on a metadata-only service. $C = 0.56$, $I = 0$, $A = 0$, on an asset with CR=0.5 (Low), IR=AR=1.5.

$$\mathrm{ISC} = 1 - (1 - 0.28)(1)(1) = 0.28,$$
$$S = 0.28/0.915 = 0.306 \;\Rightarrow\; W = \text{Narrow} \;\Rightarrow\; \boxed{\text{N2}}.$$

A confidentiality leak on a service that holds only operational metadata is reconnaissance, not a debilitating breach — captured by the low CR.

Example 5 — the technical-impact floor. A "weak" RCE with $C = I = A = 0.22$ (Low) on a High/High/High asset, single-agency. Without the floor: ISC $= 1 - (1 - 0.33)^3 = 0.699$, $S = 0.764 \Rightarrow$ Disruptive $\Rightarrow$ N3. If an authoritative source reports technical impact `total`, the touched dimensions floor to 0.56, giving $S = 1.0 \Rightarrow$ Debilitating $\Rightarrow \boxed{\text{N4}}$.

9 Assigning CR/IR/AR: archetypes (an example, not a standard)

The model in Section 5 is only as good as the CR/IR/AR assignment that feeds it. Assigning requirements per individual asset does not scale and invites drift. A practical mechanism is to define a small catalog of *asset archetypes*, each carrying a fixed CR/IR/AR and an amplifier flag, and to tag each asset with one archetype.

> *The archetype catalog in Appendix A is illustrative. A conforming implementation* MUST *derive its CR/IR/AR assignment from its own system categorization (FIPS-199 impact levels, data inventory, authorization boundary). It* MAY *adopt the example catalog as a starting point, but each CSP* SHOULD *own and justify its mapping. Two providers with different data inventories can legitimately assign the same software different requirements.*

The classification rule we recommend is *control-plane lens first*: if an asset can deploy, orchestrate, hold cross-estate credentials, or actuate configuration, classify it by that control function regardless of the data it stores; otherwise classify by the data it holds. The same physical software lands in different archetypes by role — an in-memory store used as a cache is `app-tier`, the same software used as a session/token store is `identity-secrets`, and used as a job broker is `data-backbone`.

10 Determinism, governance, and defensibility

- **Determinism.** Given the same (CVE vector, archetype, VER axes), the method yields the same PAIN and deadline on every run and for every analyst.
- **Two human inputs only.** An asset needs exactly two tags (`asset-archetype`, `multi-agency`); everything else is derived.
- **Governed calibration.** The word thresholds (Eq. (3)) and the EPSS threshold are the only tunable knobs and MUST live in governed configuration, not in ad-hoc cluster state.
- **Auditability.** Each finding can carry the full derivation: the resolved archetype and its source, CR/IR/AR, S, the word, the scope, and the selected matrix cell.

11 Reference architecture and sample scan

Figure 1 shows a representative deployment with each component tagged by archetype. Table 2 shows the corresponding per-finding output for a fictional Class C, single-agency offering. The PAIN column is computed by the method above; the Classical Severity column is the scanner's qualitative rating, shown to make the decoupling explicit.

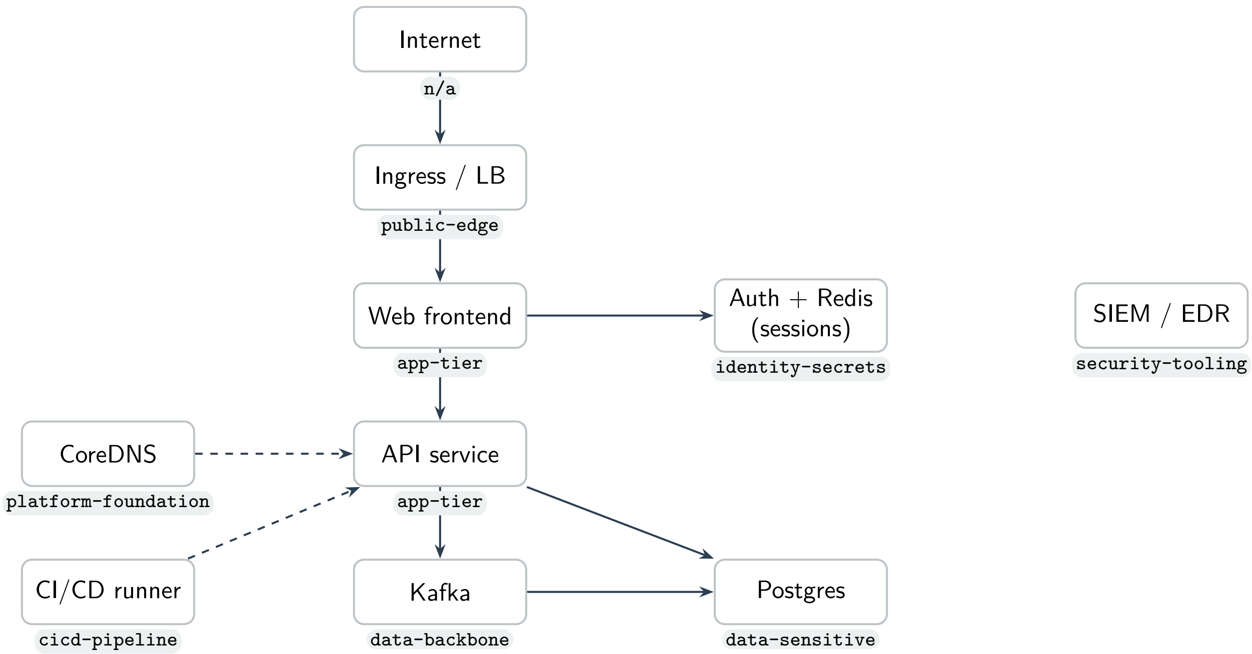

Figure 1: Reference architecture; each node carries its `asset-archetype` tag.

CVE	Resource (archetype)	Classical	EPSS	Internet	PAIN	Remediation
CVE-2026-1001	ingress (`public-edge`)	CRITICAL	0.97	yes	N4	4 days
CVE-2026-1002	payments-db (`data-sensitive`)	CRITICAL	0.94	no	N4	8 days
CVE-2026-1003	redis (`identity-secrets`)	HIGH	0.50	no	N4	64 days
CVE-2026-1004	kafka (`data-backbone`)	LOW	0.76	no	N4	8 days
CVE-2026-1005	web (`app-tier`)	MEDIUM	0.20	yes	N3	128 days
CVE-2026-1006	coredns (`platform-foundation`)	MEDIUM	0.08	no	N2	192 days

Table 2: Sample VDR scan output (fictional data; Class C, single-agency). PAIN is computed from the archetype's CR/IR/AR and the CVE impact vector; the deadline is M[C][PAIN][column]. Note CVE-2026-1004: a *Low* vendor severity still yields N4 because it is an availability-High DoS on a High-availability-requirement asset (Example 3).

12 Relationship to CVSS v4.0

This method is expressed in CVSS v3.1 terms because the v3.1 Environmental group provides a closed-form Modified Impact Sub-Score (Eq. (1)) with explicit CR/IR/AR multipliers. CVSS v4.0 reworks impact into Vulnerable-System (`VC/VI/VA`) and Subsequent-System (`SC/SI/SA`) metrics, removes the `Scope` metric, and scores via a lookup "MacroVector" rather than a formula; CR/IR/AR persist but feed that lookup. A v4.0-only finding can be *approximated* by mapping `VC/VI/VA` onto $C/I/A$ in Eq. (1), at the cost of ignoring Subsequent-System impact. While NVD remains v3.1-dominant, an implementation SHOULD prefer the v3.1 vector and MAY treat v4.0 via this approximation until a native v4.0 environmental scorer is warranted.

13 Security Considerations

The method's integrity depends on the trustworthiness of two inputs: the asset archetype tags and the VER axes (EPSS / exploitation / reachability). Tag spoofing that *lowers* an archetype is a downgrade attack; the fail-safe default and governed calibration mitigate accidental under-classification, but tag assignment SHOULD be controlled like any other security configuration. The method does not detect vulnerabilities; it prioritizes the output of a scanner and inherits that scanner's coverage and accuracy.

14 Conclusion

FedRAMP Rev5 VDR/VER specifies the vocabulary and the axes of vulnerability prioritization but leaves the classifier unspecified. That classifier need not be invented: the CVSS Environmental metric group already encodes "re-weight impact by what is at stake," which is precisely the agency-impact question. By assigning each asset its CR/IR/AR — via archetypes or any other systematic scheme the CSP owns — and evaluating the two VER axes, a provider obtains a deterministic, auditable, and standards-grounded PAIN and remediation deadline for every finding. We offer the example archetype catalog not as a standard but as an existence proof; we encourage each CSP to publish its own.

A Example archetype catalog

Illustrative only (see Section 9). "Amp" marks scope amplifiers.

B Remediation deadline matrices

Days; 0.5 = 12 hours. Columns in order LEV+IRV / LEV+NIRV / NLEV. PAIN-1 has no FedRAMP deadline (any class). Values illustrative of a representative VDR-TFR-PVR profile.

Archetype	Lens	CR	IR	AR	Amp	Typical members
`cicd-pipeline`	control	H	H	H	✓	build/deploy runners, artifact signing, registries
`orchestrator`	control	H	H	H	✓	control plane, etcd, scheduler, coordination
`config-actuation`	control	H	H	H	✓	IaC/GitOps, schema registry, admin/migration
`identity-secrets`	control	H	H	H	✓	IdP/SSO, KMS, secrets managers, session stores
`security-tooling`	control	H	H	M		scanners, SIEM, EDR, runtime security
`change-record`	control	M	M	M		ITSM/ticketing (record only)
`platform-foundation`	control	L	H	H	✓	DNS, NTP, service discovery, L4 internal LBs (metadata only)
`data-sensitive`	data	H	H	H		PII/CUI datastores
`data-backbone`	data	H	H	H	✓	queues, brokers, the system-of-record DB
`app-tier`	data	M	M	H		stateless services, APIs, UIs, caches
`batch-analytics`	data	M	M	L		ETL, reporting, analytics jobs
`public-edge`	data	L	L	H		load balancers, public web, ingress
`internal-tooling`	data	L	L	L		dashboards, metrics/log agents
`dev-test`	data	L	L	L		non-production
`unclassified`	—	H	H	H		fail-safe default for untagged assets

	Class A / B			Class C			Class D		
PAIN	L+I	L+N	NLEV	L+I	L+N	NLEV	L+I	L+N	NLEV
N5	4	8	32	2	4	16	0.5	1	8
N4	8	32	64	4	8	64	2	8	32
N3	32	64	192	16	32	128	8	16	64
N2	96	160	192	48	128	192	24	96	192